

1. Модуль учета клиентов

АГЕНДА: 28 апр. 2026 г.

№	Вопрос	Пояснение	Ответ (ориентиром на баг до 10-20к клиентов)	Автор
1. API и ИНТЕГРАЦИИ				
1	Можем ли мы использовать Kong вместо NGINX для API Gateway?	Kong поддерживает большее число возможностей из коробки: • микросервисная архитектура (много маленьких сервисов). • разные способы аутентификации для Разных сервисов • гибкая маршрутизация запросов • добавление маршрутов через API без доступа к серверу • аналитика использования API по клиентам • Из коробки поддерживает JWT, Key-Auth, OAuth 2.0, HMAC, LDAP и т.д.	Да, можем! По стандарту Gateway API Провел анализ возможностей стандарта Kubernetes Gateway API и его применимости. Мой репозиторий https://github.com/vasilokb/gateway. Хотя я пока не перешел к практическим тестам Istio, проработка теории и анализ экспертных материалов (включая статью от Slurm) позволяют сформировать архитектуру с видением. Ключевые выводы: - Gateway API ≠ API Gateway https://gateway-api.sigs.k8s.io	Билла Экартина

[/guides](#)
[/getting](#)
[-started](#)
[/migrati](#)
[ng-](#)
[from-](#)
[ingress/](#)
: Gate
way
API - э
то
универ
сальны
й
открыт
ый
станда
рт и
набор
ресурс
ов в
K8s
(HTTP
Route,
Gatewa
y), а
API
Gatewa
y - это
функц
иональ
ная
роль
(или
конкре
тный
софт,
как
Kong
или
Nginx),
реализ
ующая
бизнес-
логику
вроде
Auth
или
Rate
Limit.
Станда
рт
позвол
яет
нам
описыв
ать
правил
а один
раз и
не
зависет
ь от
выбора
конкре
тного
исполн
ителя.

Эволю
ция
подход
ов:
Анализ
различ
ных
подход
ов (от
чистог
о
Ingress
до
полноц
енного
API
Gatewa
y)
показы
вает,
что
для
микрос
ервисн
ой
архите
ктуры
оптима
лен

путь Service Mesh. Gateway API здесь выступает единым интерфейсом управления как для внешнего, так и для внутреннего трафика (инициатива GAMA).

- Роль Istio в банковской среде: В банковских приложениях автоматизация mTLS скорее всего этот стандарт де-факто. Использование Istio в качестве реализации Gateway API позволяют нам закрыть вопрос шифрования межсервисными сообщениями, не перегружая код разработчиков логикой работы с сертификатами.

- Архитектурная чистота: Мы разделим обязанности: Control Plane (istiod)

управл
яет
полити
ками,
а
Sidecar
-
прокси
(Envoy
) у
каждог
о
сервис
а
обеспе
чивают
выпол
нение
этих
полити
к и
дают
нам
полну
ю
наблю
даемос
ть
(Obser
vability
) без
участи
я
прикла
дного
кода.

Конф
отдель
ный
продук
т со
своими
жизнен
ным
циклом
(обнов
ления,
патчи,
безопи
сности,
совмес
тимость
с
платини
он,
настро
йка
логгов
и
многого
другог
). Кто в
команд
е
будет
за это
отвеча
ть?

Мы
эпаса
Ева
или
Сте,
чтобы
писать
кастом
ные
платини
вы,
если
встрее
мных
не
хватит?

[illegible]

	Kong
	написа
	n na
	Lua
	поверх
	OpenK
	esty. y
	нас в
	команд
	есть
	опыт
	отладк
	n Lua
	кодв?
	y нас
	больше
	десяти
	микро
	сравно
	в?
	Назови
	те три
	функц
	ии
	Kong-
	без
	которы
	x выг
	не
	можете
	обойти
	сь в
	ближа
	ющие
	t2
	месяца
	разраб
	отки
	MVP-
	Един
	таких
	нет и
	чем
	нам
	Kong?

2	Необходима ли в API Gateway поддержка ключа идемпотентности в запросах?	Если да, то где будет храниться кэш с ключом идемпотентности и ответами сервисов? В каком формате?	а зачем для MVP кэш? БД со своим кэшем не будет справляться? реализуем идемпотентность на бэке API Gateway у это транспортный слой. Он не должен знать какой запрос можно повторить, а какой нет (создание клиента / можно, повторный перевод 100P / нельзя), какой ответ считать дубликатом, что делать при несопадении тела повторного запроса с оригиналом Идемпотентность бизнес-логика. Она принадлежит сервису, который обрабатывает операцию	Билля Экатерина
3	В каком слое и на каком этапе должна происходить конвертация JSON в proto и обратно?	В API gateway после проверки JWT и ответа от PDP? В каком формате данных должны обмениваться API Gateway и PDP - JSON или proto?	Какие конкретные проблемы мы решаем? Protobuf в нашем MVP с тремя сервисами и < 1000 RPS?	Билля Экатерина

4	Проверка JWT должна проходить в API Gateway самостоятельно без отправки запроса в Keycloak?	Согласно спецификации Keycloak, он занимается выдачей и обновлением JWT токенов клиентам, но проверку токена осуществляет Gateway самостоятельно	Да, API Gateway должен проверять JWT самостоятельно, без синхронного запроса в Keycloak	Би ля ев а Ек ат ср ина
---	---	--	---	--

5	Как часто Keycloak должен отправлять сертификат в API Gateway для локальной проверки JWT?	Один раз в самом начале работы или регулярно?	API Gateway не проверяет каждый JWT запросом к Keycloak это было бы медленно. Вместо этого кэшируем публичные ключи (JWKS) с TTL порядка 5 минут. Механизм: Первый JWT забирем из Keycloak, кэшируем, валидируем локально. Последующие JWT - валидация по кэшу, без обращения к Keycloak. JWT с неизвестным kid или просроченный кэш - синхронно обновляем JWKS из Keycloak, затем валидируем обновление лениво, по запросу. Если трафика нет лишнего обращения к Keycloak тоже нет.	Билла Экстерна
6	Вопрос про роли доступа: к нам ходят сервисы банка? сервис к нам ходит напрямую или у них тоже должен быть	От этого зависит как мы должны описывать ролевую модель и роли доступа в системе		

	какой-то интеграционный модуль, который будет маршрутизировать эти запросы? как мы должны понимать какие доступы есть у того или иного сервиса? как мы должны их выдавать?		В архитектуре MVP существует два потока вызовов. Внешние системы обращаются к API Gateway, которые проверяют JWT, а затем проксируют запрос в нужный сервис. А внутренние сервисы вызывают друг друга напрямую без Gateway. При прямом вызове сервис-инициатор прокидывает заголовки X-User-Roles (или внутренний служебный токен), а сервис-получатель доверяет этим заголовкам, поскольку вызов идёт из доверенной сети кластера. Отдельного интеграционного модуля не требуется.
--	---	--	--

			Но для исходящих запросов из наших сервисов в сторонние платформы (процессинг, ЦБ, НСПК, смежные системы) отдельный интеграционный модуль или шлюз исходящих вызовов в действительном нужен.	
7	Последовательность слоев в слое входа и безопасности: точно ли гетвей должен быть в начале? разве не должны сначала выдать токен через кейклок? А также насколько это реализуемо с учетом ограниченного количества мощностей (2-4 виртуальные машины,)	От этого зависит описание логики взаимодействия систем в слое входа и безопасности	API Gateway первый слоем для всех входящих запросов. Получение токена отдельный процесс. Когда клиент ещё не аутентифицирован, Gateway перенаправляет его на страницу логина Keycloak (HTTP 302). После логина Keycloak выдаёт JWT, и клиент повторяет запрос уже с токеном.	Г а та ль ск ая Н ат ал ья

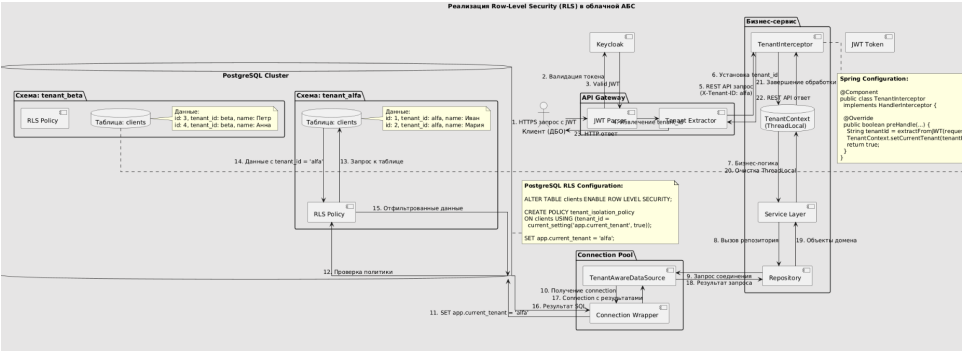
Keycloak не перед Gateway, а рядом: он используется для выдачи токенов (прямой вызов или через редирект), но каждый запрос с токеном сначала идёт в Gateway. У, который локально валидирует JWT (проверяет подпись, срок, tenant_id) и только потом проксирует в сервисы.

				(2-4 VM): схема реализ уема. На одной VM можно размес тить Postgre SQL и Keyclo ak (Keycl oak требуе т миним ум 2 ГБ ОЗУ и 2 ядра, при низкой нагруз ке совме щение допуст имо). На второй VM G ateway и все три сервис а (клиен тов, счетов, транза кций). Остав шиеся 1-2 VM можно исполь зовать для реплик и БД или дополн ительн ых инстан сов сервис ов.
--	--	--	--	--

2. АРХИТЕКТУРА В ЦЕЛОМ

1	На диаграмме C4 внутренние вызовы между микросервисами подписаны протоколом gRPC, на нее мы ориентируемся при проектировании. Действительно ли нам необходимо использование gRPC или можно сделать все на REST?	The diagram shows a central blue box labeled «container» API Gateway. Inside the box, it says «Входящая маршрутизация, аутентификация, rate limiting». Arrows point into the box from the left. Arrows point from the box to three separate boxes below it, each labeled [HTTP/gRPC]. An arrow points from the top right into the box, labeled [HTTPS].	REST	Бил сва Ек ат ср ина
---	---	--	------	-------------------------------------

2 Следуюя этой диаграмме у нас на АБС должны храниться и клиенты банка, но ПО сказал, что мы не должны их хранить у себя, только инфомрацию о самих банках (наши клиенты), а по клиентам банка только получать данные, обрабатывать и отправлять ответ.
Так на что нам в итоге ориентироваться?



Вам придёт
ся кажды
й раз при
открыт
ии счета
или любом
запросе
с получе
ть все дан
ные о клиент
е из внешн
его источн
ика - это
нерац
иональн
о для MVP,
но технич
ески возмо
жно. Уточн
ите у ПО
допуст
имость хран
ения миним
альной инфор
мации (идент
ификатор
клиента,
а призна
к KYC). Без
этого счёт
не открыт
ь - он всег
да кому-то
принадлежит

Гал
та
ль
ск
ая
Н
ат
ал
ья

3	ПО предложил добавить в архитектуру системы оркестратор для маршрутизации входящих и внутренних запросов. Какой вариант архитектуры предпочтительнее для нашей системы - оркестрация или хореография?		Для MVP с тремя сервисами и синхронными REST-вызовами отдельный оркестратор не нужен. Сервис транзакций уже выполняет роль координатора: он последовательно вызывает сервис счетов и сервис клиентов, собирает результаты и принимает решение. Это inline-оркестрация стандартный паттерн для простых потоков. У нас 2-3 шага в каждом потоке и фиксированная логика. Какую конкретную проблему решит отдельный оркестратор в MVP?	Билля Экатерина
4	Необходимо ли нам детально проработать административный модуль и модуль логирования перед тем как переходить к описанию микросервиса Клиенты или мы можем перейти сразу к МС Клиенты?		"протоколирование" как решение	Билля Экатерина

3. Уточнение значений

1	Что подразумевается под BYPASSRLS и для чего он нужен?		атрибу т роли в постгр есе	Га та ль ск ая Н ат ал ья
ВОПРОСЫ ПО KEYCLOAK				
1	Как часто обновляется публичный ключ Keycloak? Нужен ли автоматический перевыпуск?	Публичный ключ используется API Gateway для валидации подписи JWT-токенов. Если ключ меняется, API Gateway должен получить новый. Если обновление происходит редко (раз в год), можно перезагружать ключ вручную или при рестарте. Если часто (раз в месяц или чаще), нужен автоматический механизм (например, API Gateway периодически запрашивает JWKS эндпоинт Keycloak). Без автоматического обновления API Gateway перестанет валидировать токены после смены ключа.	ленив ое обновл ение JWKS с TTL 5 минут: API Gatewa у провер яет kid в JWT, и если ключа нет в кэше или кэш устаре л, синхро нно загруж ает свежий JWKS из Keyclo ak. Никако й фоново й задачи или ручног о переза пуска не требуе тся	Ф ил ип по в М их аил
2	Как отозвать JWT-токен до истечения срока (revocation)?	JWT-токены по своей природе не отзываются — они действительны до истечения срока (1 час). Но если client_secret скомпрометирован или банк заблокирован, нужно иметь возможность немедленно запретить доступ. Варианты: чёрный список токенов (хранить в Redis), короткое время жизни токена (уже есть 1 час), или использовать reference-токены (Keycloak проверяет каждый токен через БД). Без механизма отзыва при компрометации банк сможет использовать токен ещё час.	TTL 1 час	Ф ил ип по в М их аил
ВОПРОСЫ ПО PDP (OPA)				
1	Какое максимальное время ожидания ответа от PDP вы рекомендуете для API Gateway? Нужна цифра, исходя из архитектуры и ожидаемых задержек в кластере.	API Gateway перед маршрутизацией запроса к оркестратору отправляет запрос в PDP для проверки прав доступа. Если PDP не отвечает в течение определённого времени, API Gateway должен принять решение: отклонить запрос (безопасно, но недоступно) или пропустить (доступно, но рискованно).	50 мл сек пдп - как набор ролей и для каждой пропис аны улы мметод ы и призна к: разреш ено или нет (как табл) размещ аете в постгрес раз в сутки ttl	Ф ил ип по в М их аил

2	Нужен ли fallback-сценарий при недоступности PDP?	Если PDP недоступна, API Gateway не может проверить права. Fallback-сценарий может быть: отклонить запрос (безопасно, но недоступно), разрешить запрос (доступно, но рискованно), или использовать кэшированные решения из Redis. Вопрос: что делать, когда PDP не отвечает?	нужно обсужд ать с бизнес ом	Ф ил ип по в М их аил
3	Нужно ли разграничение политик по tenant_id внутри PDP?	tenant_id — код банка. Если политики разграничены по tenant_id, каждый банк может иметь свои правила доступа. Если нет — политики едины для всех банков. Вопрос: должна ли авторизация зависеть от того, какой банк делает запрос, или правила едины для всех?	1 банк видит только свои данные - далее обсужд ать с бизнес ом	Ф ил ип по в М их аил
4	Могут ли политики различаться для разных банков?	Это уточнение к вопросу 10. Если да, то нужно хранить политики с учётом tenant_id. Например, банк с ролью bank_client может иметь доступ только к своим данным, а другой банк — к дополнительным методам. Вопрос: нужна ли гибкость на уровне банков?	к ТЛ	Ф ил ип по в М их аил

АГЕНДА: 20 апр. 2026 г.

№	Вопрос	Пояснение	Ответ (ориентируемся на банк до 10-20к клиентов)	Автор
1. МУЛЬТИТЕНАНТНОСТЬ И ИЗОЛЯЦИЯ ДАННЫХ				
1	Как технически организована изоляция данных разных банков? (отдельные схемы PostgreSQL, отдельные БД, tenant_id + RLS?)	РО говорил «данные не должны пересекаться», хотелось бы знать механизм.	данные будут храниться в одной базе данных PostgreSQL + RLS	Фи ли пп ов Ми ха ил
2	Как будет организован онбординг нового банка? (через API, через админ-панель, вручную через БД?)	Будет влиять на архитектуру и безопасность.	вручную	Фи ли пп ов Ми ха ил
2. API И ИНТЕГРАЦИИ				
3	HTTP, HTTPS?	Микросервисы могут быть распределены по сети, для дополнительной защиты (в банковской сфере)	HTTPS	Тр ош ко Ди ана
3. ПРОИЗВОДИТЕЛЬНОСТЬ И МАСШТАБИРОВАНИЕ				
4	Какое максимальное время ответа API закладываем? (1 сек, 3 сек, 5 сек?)	РО говорил «зависит от системы» — хотелось бы понимать конкретные цифры	к бизнесу, но можно предусмотреть 300 мил сек	Фи ли пп ов Ми ха ил
5	Какое максимальное количество запросов в секунду (RPS) должна выдерживать система?	Для масштабирования	к бизнесу	Фи ли пп ов Ми ха ил

4. БЕЗОПАСНОСТЬ

6	Как защищены данные от прямых изменений администраторами БД (DBA)? Логируются ли их действия в отдельной системе?	Требование регуляторов	мы можем присмотреть изменяемую БД (ластик серч)	Филиппов Михаил
7	На каком уровне шифруются персональные данные? (в приложении, в БД, на диске?)	152-ФЗ	сначала определиться с доступами потом с какими именно данными будем шифровать	Филиппов Михаил
8	Где хранятся ключи шифрования? Как организована ротация ключей без остановки системы?	Безопасность	в след раз - Василий посмотрит	Филиппов Михаил

5. АУДИТ И ЛОГИРОВАНИЕ

9	Все действия логируются через Kafka? Кто пишет в Kafka — наш модуль или отдельный сервис?	Архитектура аудита	сервис аудита и логирования - добавить модуль или предусмотреть сразу Нужно определить категорию событий для записи (спросить у РО) (как идея в каждом сервисе предусмотреть логи в таблице)	Филиппов Михаил
---	---	--------------------	---	-----------------

6. ОТКАЗОУСТОЙЧИВОСТЬ

				Филиппов Михаил
10	Как обеспечивается отказоустойчивость? Есть ли горячее резервирование, кластеризация?	Банковская система должна работать 24/7	для МВП уточнить сколько может быть простой (подумать над CQRS-паттерн)	Филиппов Михаил
11	Что происходит с операциями, которые были в момент падения сервиса? (очереди, retry, компенсации?)	Для надёжности	сначала определиться какие операции должны не попасть под падение - потом решать а так Outbox-паттерн	Филиппов Михаил

12	Какая политика retry и timeout при интеграциях с другими модулями?	Когда наш модуль «Клиенты» вызывает другие модули (например, модуль счетов для проверки статуса счёта, кредитные системы для передачи данных, compliance для проверки по стоп-листам), могут возникать временные сбои: модуль перегружен, сеть «потеряла» пакет, сервер на секунду завис. Нам нужно понять: 1. Timeout: сколько секунд ждать ответа? 2. Retry: сколько раз повторять? 3. Интервал: с какой задержкой между повторами? 4. Действие при сбое: отказывать сразу, ставить в очередь или повторять?	выбирать исходя из политики сервисов (логики) просто реализуйте по-простому	Филиппов Михаил
----	--	---	---	-----------------

7. МОДЕЛЬ ДАННЫХ (ТЕХНИЧЕСКАЯ)

13	Идентификационные, персональные, документальные данные — хранить в одной таблице или в разных (нормализация)?	Влияет на производительность и сложность запросов	можно использовать и нормализацию и таблицы и есть еще data vault - таблица (70% работы)	Филиппов Михаил
----	---	---	---	-----------------

8. АРХИТЕКТУРА В ЦЕЛОМ

15	У нас есть отдельный интеграционный модуль (из C4-диаграммы)? Если да, то какие задачи он берёт на себя? Все ли интеграции с другими модулями (счета, кредитные системы, compliance) идут через него или какие-то напрямую?	Границы модулей	интеграц. модуль - для внешних	Филиппов Михаил
18	Что происходит при недоступности модуля счетов? Платежи встают в очередь или отклоняются?	Надёжность	нужно предусмотреть fallback события и узнать у ро какие события подлежат обработке	Филиппов Михаил